

IP Servisleri

ARP Vulnerabilities (ARP Güvenlik Açıkları)

- Ana bilgisayarlar, belirli bir IP adresine sahip bir ana bilgisayarın MAC adresini belirlemek için segmentteki diğer ana bilgisayarlara ARP isteği yayınlar. ARP isteğinde eşleşen IP adresine sahip ana bilgisayar bir ARP yanıtı gönderir.
- Herhangi bir istemci, “gratuitous – nedensiz, kendi isteğiyle” ARP olarak adlandırılan, istenmeyen bir ARP Yanıtı gönderebilir. Bir ana bilgisayar, gratuitous bir ARP gönderdiğinde, alt ağdaki diğer ana bilgisayarlar, arp tablolarında gratuitous ARP’de bulunan MAC adresini ve IP adresini depolar.
- ARP’nin bu özelliği ayrıca herhangi bir ana bilgisayarın herhangi bir IP veya MAC’in sahip olduğunu iddia edebileceği anlamına gelir. Bir tehdit aktörü, yerel ağdaki ARP önbelleklerini zehirleyerek trafiği yönlendirmek için bir MITM saldırısı oluşturabilir.

ARP Cache Poisoning (ARP Önbellek Zehirlenmesi)

ARP önbellek zehirlenmesi, çeşitli ortadaki adam saldırılarını başlatmak için kullanılabilir.

- PC-A, varsayılan ağ geçidinin (R1) MAC adresini gerektirir; bu nedenle 192.168.10.1 MAC adresi için bir ARP Talebi gönderir.
- R1, ARP önbelleğini PC-A’nın IP ve MAC adresleriyle günceller. R1, PC-A’ya bir ARP Yanıtı gönderir ve daha sonra ARP önbelleğini R1’in IP ve MAC adresleriyle güncelleştirir.
- Tehdit aktörü belirtilen hedef IP adresleri için kendi MAC adresini kullanarak iki sahte ARP Yanıtı gönderir. PC-A, ARP önbelleğini şimdi tehdit oyuncusunun ana bilgisayar MAC adresini işaret eden varsayılan ağ geçidi ile günceller. R1 ayrıca ARP önbelleğini tehdit oyuncusunun MAC adresini gösteren PC-A’nın IP adresiyle günceller.

ARP zehirlenmesi saldırısı pasif veya aktif olabilir. Pasif ARP zehirlenmesi, tehdit aktörlerinin gizli bilgileri çaldığı yerdir. Aktif ARP zehirlenmesi, tehdit aktörlerinin transit verileri değiştirdiği veya kötü amaçlı verileri enjekte ettiği yerdir.

DNS Saldırıları

- Domain Name Service – Etki Alan Adı Hizmeti (DNS) Protokolü, www.cisco.com gibi kaynak adlarıyla IPv4 veya IPv6 adresi gibi gerekli sayısal ağ adresiyle eşleşen otomatik bir hizmet tanımlar. Sorguların, yanıtların ve verilerin biçimini içerir ve DNS yanıtı türünü tanımlamak için kaynak kayıtları (RR) kullanır.
- DNS'nin güvenliğini sağlama genellikle göz ardı edilir. Bununla birlikte, bir ağın çalışması için çok önemlidir ve buna göre emniyet altına alınmalıdır.
- DNS saldırıları aşağıdakileri içerir:
 - DNS açık çözümleyici saldırıları
 - DNS gizi saldırıları
 - DNS etki alanı gölgeleme saldırıları
 - DNS tünel saldırıları

DNS Açık Çözümleyici Saldırıları: DNS açık çözümleyici, yönetim etki alanının dışındaki istemcilerden gelen sorguları yanıtlar. DNS açık çözümleyicileri tabloda açıklanan birden çok kötü amaçlı etkinliğe karşı savunmasızdır.

DNS Çözümleyici Güvenlik Açıkları	Açıklama
DNS önbellek zehirlenmesi saldırıları	Tehdit aktörleri, kullanıcıların yasal sitelerden kötü amaçlı sitelere yönlendirmek için sahte kayıt kaynağı (RR) bilgilerini bir DNS çözümleyicisine gönderir. DNS önbellek zehirlenmesi saldırılarının tümü, DNS çözümleyicisine kötü amaçlı etkinlikler için RR bilgileri sağlayan kötü amaçlı bir ad sunucusu kullanmasını bildirmek için kullanılabilir.
DNS yükseltme ve yansıtma saldırıları	Tehdit aktörleri, saldırı hacmini artırmak ve gerçek bir saldırı kaynağını gizlemek için DNS açık çözümleyicilere DoS ve DDoS saldırıları kullanır. Tehdit aktörleri, hedef ana bilgisayarın IP adresini kullanarak açık çözümleyicilere DNS mesajları gönderir. Bu saldırılar mümkündür, çünkü açık çözümleyici soru soran herkesin sorgularına yanıt verecektir.
DNS kaynak kullanım saldırıları	DNS açık çözümleyicilerinin kaynaklarını tüketen bir DoS saldırısı. Bu DoS saldırısı, DNS açık çözümleyicinin işlemlerini olumsuz etkilemek için mevcut tüm kaynakları tüketir. Bu DoS saldırısının etkisi, DNS açık çözümleyicinin yeniden başlatılmasını veya hizmetlerin durdurulmasını gerektirebilir.

DNS Gizli Saldırıları: Tehdit aktörleri kimliklerini gizlemek için saldırılarını gerçekleştirmek için tabloda açıklanan DNS gizli tekniklerini de kullanırlar.

DNS Gizli Teknikleri	Açıklama
Fast Flux (Hızlı Akış)	Tehdit aktörleri, kimlik avı ve kötü amaçlı yazılım dağıtım sitelerini, hızla değişen güvenliği ihlal edilmiş DNS ana bilgisayarlarının ağının arkasına gizlemek için bu tekniği kullanır. DNS IP adresleri dakikalar içinde sürekli olarak değiştirilir. Bot ağları, kötü amaçlı sunucuların tespit edilmesini etkili bir şekilde gizlemek için genellikle Fast Flux tekniklerini kullanır.
Double IP Flux (Çift IP Akışı)	Tehdit aktörleri, ana bilgisayar adını hızlı bir şekilde IP adresi eşlemelerine değiştirmek ve ayrıca yetkili ad sunucusunu değiştirmek için bu tekniği kullanır. Bu, saldırının kaynağını tanımlama zorluğunu artırır.
Domain Generation Algorithms (Alan Adı Üretimi Algoritmaları)	Tehdit aktörleri, bu tekniği kötü amaçlı yazılımlarda, daha sonra komut ve kontrol (C&C) sunucularına buluşma noktaları olarak kullanılabilecek rastgele etki alanı adları oluşturmak için kullanır.

DNS Domain Shadowing - Etki Alanı Gölgeleme Saldırıları: Etki alanı gölgelemesi, saldırılar sırasında kullanılacak birden çok alt etki alanını sessize oluşturmak için etki alanı hesabı kimlik bilgilerini toplayan tehdit aktörünü içerir. Bu alt alanlar genellikle üst etki alanının gerçek sahibini uyarmadan kötü amaçlı sunuculara işaret eder.

DNS Tünelleme

- DNS Tüneli kullanan tehdit aktörleri, DNS dışı trafiği DNS trafiğine yerleştirir. Bu yöntem, bir tehdit aktörü korumalı bir ağ içindeki botlarla iletişim kurmak veya kuruluştan veri sızdırmak istediğinde genellikle güvenlik çözümlerini atlatır. DNS tüneli, bir botnet'e gönderilen CnC komutları şu şekilde çalışır:
 - Komut verileri birden fazla kodlanmış parçaya bölünür.
 - Her yığın, DNS sorgusunun daha alt düzey bir etki alanı adı etiketine yerleştirilir.
 - Sorgu için yerel veya ağa bağlı DNS'den yanıt alınmadığından, istek İSS'nin özyinelemeli DNS sunucularına gönderilir.
 - Özyinelemeli DNS hizmeti, sorguyu tehdit oyuncusunun yetkili ad sunucusuna iletir.
 - Parçaları içeren tüm sorgular gönderilinceye kadar işlem tekrarlanır.
 - Tehdit oyuncusunun yetkili ad sunucu etkilenen cihazlardan DNS sorguları aldığı anda, kapsüllenmiş, kodlanmış CnC komutlarını içeren her DNS sorgusu için yanıtlar gönderir.
 - Güvenliği ihlal edilen ana bilgisayardaki kötü amaçlı yazılım parçaları birleştirir ve DNS kaydında gizlenmiş komutları yürütür.

- DNS tünellemesini durdurmak için ağ yöneticisinin DNS trafiğini denetleyen bir filtre kullanması gerekir. Ortalamadan uzun veya şüpheli alan adına sahip DNS sorgularına dikkat edin.

DHCP

- DHCP sunucuları, istemcilere dinamik olarak IP yapılandırma bilgileri sağlar.
- İstemci bir DHCP keşif mesajı yayınlamaktadır. DHCP, istemcinin kullanabileceği adresleme bilgilerini içeren tek noktaya yayın teklifiyle yanıt verir. İstemci, teklifi kabul ettiğini sunucuya bildirmek için bir DHCP isteği yayınlar. Sunucu, isteği kabul eden bir tek noktaya yayın onayı ile yanıt verir.

DHCP Saldırıları

- Bir DHCP Spoofing – Kimlik Sahtekarlığı Saldırısı, sahte bir DHCP sunucusu ağa bağlandığında ve yasal istemcilere yanlış IP yapılandırma parametrelerini sağladığında gerçekleşir. Sahte bir sunucu çeşitli yanıltıcı bilgiler sağlayabilir:
 - Yanlış varsayılan ağ geçidi – Tehdit aktörü, bir MITM saldırısı oluşturmak için geçersiz bir ağ geçidi veya ana bilgisayarının IP adresini sağlar. Davetsiz misafir ağ üzerinden veri akışına müdahale ettiği için bu tamamen tespit edilemez.
 - Yanlış DNS sunucusu – Tehdit aktörü kullanıcıyı kötü amaçlı bir web sitesine yönlendiren yanlış bir DNS sunucusu adresi sağlar.
 - Yanlış IP adresi – Tehdit aktörü geçersiz bir IP adresi, geçersiz varsayılan ağ geçidi IP adresi veya her ikisini birden sağlar. Tehdit oyuncusu daha sonra DHCP istemcisine bir DoS saldırısı oluşturur.

Bir tehdit aktörünün, sahte bir DHCP sunucusunu hedef istemcilere aynı alt ağdaki bir anahtar bağlantı noktasına başlarıyla bağladığını varsayın. Sahte sunucunun amacı, istemcilere yanlış IP yapılandırma bilgileri sağlamaktır.

1. İstemci, bir DHCP sunucusundan yanıt arayan bir DHCP Keşfi isteği yayınlar. Her iki sunucu da mesajı alır.
2. Meşru ve aldatıcı DHCP sunucularının her biri geçerli bir IP yapılandırma parametreleriyle yanıt verir. Müşteri, alınan ilk teklife yanıt verir.
3. İstemci önceden sahte teklifi aldı. Sahte sunucudan parametreleri kabul eden bir DHCP isteği yayınlar. Meşru ve dolandırıcı sunucunun her biri isteği alır.
4. Yalnızca sahte sunucu, isteğini kabul etmesi için istemciye bir yanıt gönderir. Meşru sunucu, istek zaten onaylandığından istemci ile iletişim kurmayı durdurur.